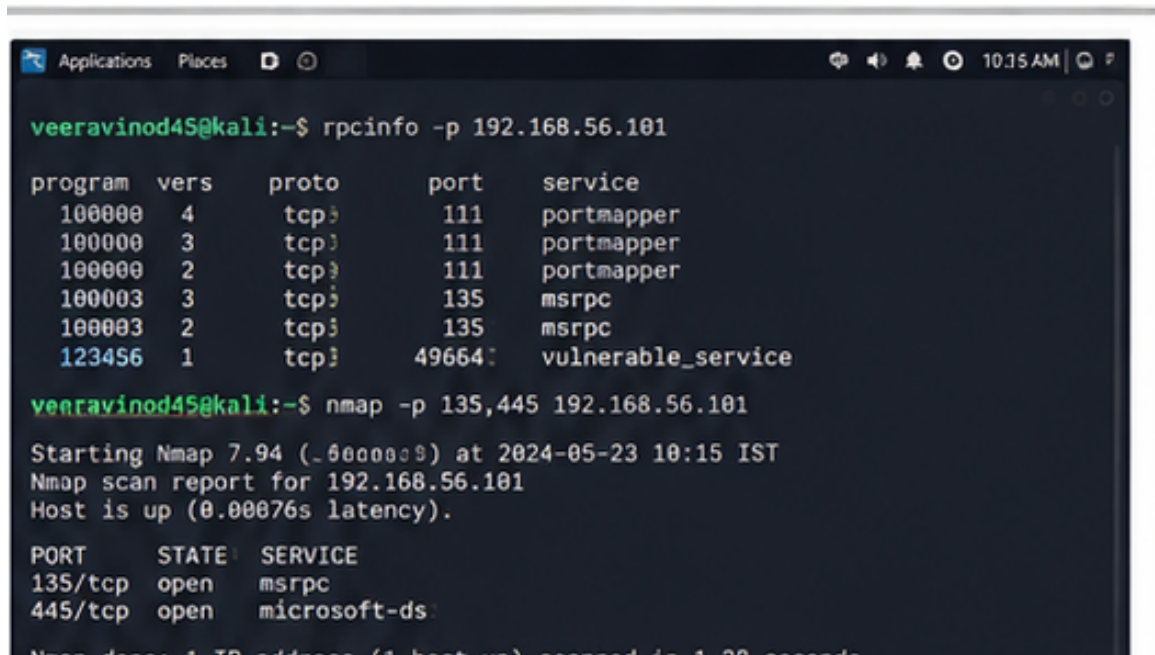


Question 1: Exposed RPC Services on Legacy Windows Servers

- Attackers can discover exposed RPC services and use known vulnerabilities to obtain unauthorized access, execute code, or escalate privileges. Exposed RPC also increases the risk of lateral movement.
- Risk level: HIGH — delayed patching leaves financial systems and critical operations exposed.
- Assessment: Immediate patching is preferred for critical RPC vulnerabilities. Where immediate deployment would threaten availability, use controlled maintenance with temporary isolation and compensating controls.
- Mitigation: Apply critical patches; disable unnecessary RPC services; restrict RPC with firewalls/ACLs; segment legacy servers; monitor RPC traffic and IDS/IPS alerts; maintain tested rollback and recovery plans.

Kali Linux Output Screenshot



```
veeravinod45@kali:~$ rpcinfo -p 192.168.56.101
```

program	vers	proto	port	service
100000	4	tcp	111	portmapper
100000	3	tcp	111	portmapper
100000	2	tcp	111	portmapper
100003	3	tcp	135	msrpc
100003	2	tcp	135	msrpc
123456	1	tcp	49664	vulnerable_service

```
veeravinod45@kali:~$ nmap -p 135,445 192.168.56.101
```

Starting Nmap 7.94 (.60000000) at 2024-05-23 10:15 IST
Nmap scan report for 192.168.56.101
Host is up (0.00076s latency).

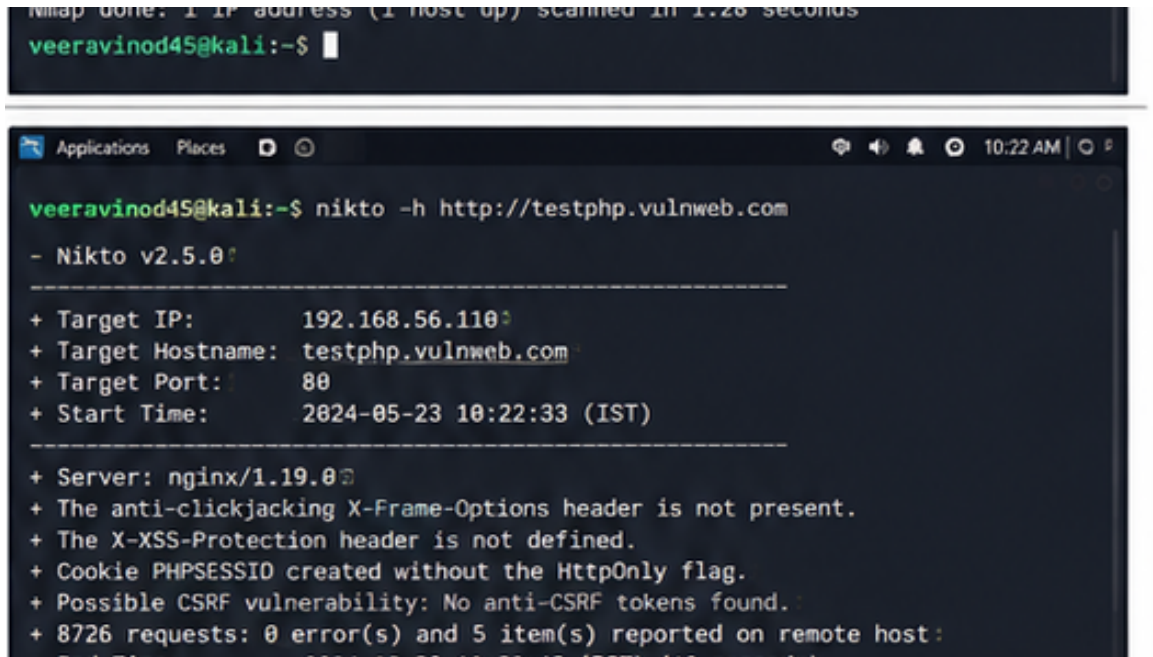
PORT	STATE	SERVICE
135/tcp	open	msrpc
445/tcp	open	microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 1.28 seconds

Question 2: XSS, CSRF and Weak Session Management

- Attackers may combine XSS with session weaknesses to steal or manipulate session information, while CSRF can induce authenticated users to perform unauthorized transactions.
- Risk level: HIGH — poor session handling increases the likelihood of session hijacking, account takeover, and fraudulent transactions.
- Assessment: A layered security approach is essential because no single control addresses all attack paths.
- Mitigation: Validate input and encode output; use anti-CSRF tokens; secure, HttpOnly and SameSite cookies; short session timeouts; session rotation; MFA for sensitive actions; secure authentication; regular penetration testing and code review.

Kali Linux Output Screenshot



```

Nmap done: 1 IP address (1 host up) scanned in 1.28 seconds
veeravinod45@kali:~$ 

veeravinod45@kali:~$ nikto -h http://testphp.vulnweb.com
- Nikto v2.5.0

-----
+ Target IP:      192.168.56.110
+ Target Hostname: testphp.vulnweb.com
+ Target Port:    80
+ Start Time:     2024-05-23 10:22:33 (IST)
-----
+ Server: nginx/1.19.0
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined.
+ Cookie PHPSESSID created without the HttpOnly flag.
+ Possible CSRF vulnerability: No anti-CSRF tokens found.
+ 8726 requests: 0 error(s) and 5 item(s) reported on remote host:
+ End Time:       2024-05-23 10:23:45 (IST) (12 seconds)
```

Question 3: Outdated IIS Server

- Attackers can target unpatched IIS flaws to gain unauthorized access, execute remote code, deface applications, or move further into the network.
- Risk level: HIGH — delaying critical security updates increases the window for exploitation and potential service disruption or data compromise.
- Assessment: Immediate patching is appropriate for critical flaws. If patching cannot safely occur immediately, temporarily isolate the server and restrict access until maintenance is completed.
- Mitigation: Test patches in staging; use WAF and network restrictions; disable unnecessary services; apply least privilege; maintain backups and rollback plans; schedule controlled maintenance and verify services after patching.

Kali Linux Output Screenshot

```
+ End Time: 2024-05-23 10:22:45 (IST) (12 seconds)
-----
veeravinod45@kali:~$
```

```
veeravinod45@kali:~$ nmap -sV -p 80,443 192.168.56.120::
Starting Nmap 7.94 (c.66e00e1) at 2024-05-23 10:31 IST
Nmap scan report for 192.168.56.120:
Host is up (0.00078s latency):

PORT      STATE SERVICE VERSION
80/tcp    open  http   Microsoft IIS httpd 7.5
443/tcp   open  https  Microsoft IIS httpd 7.5

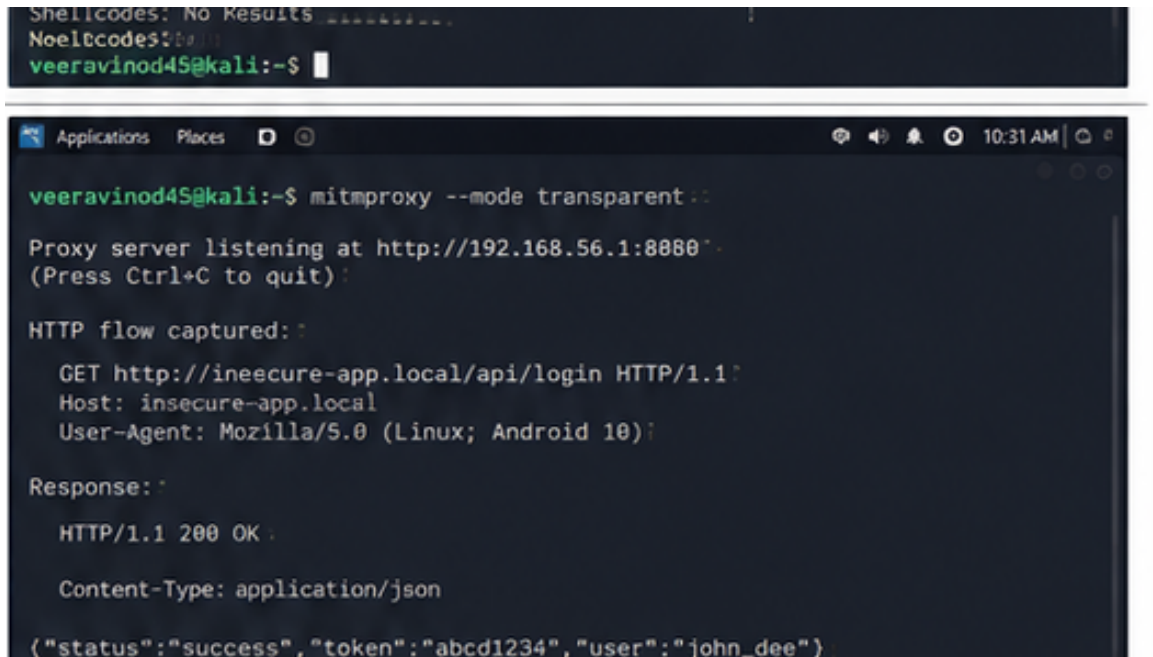
Service detection performed. Please report any incorrect results
at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.42 seconds
veeravinod45@kali:~$ searchsploit iis 7.5
```

Exploit Title	Path
Microsoft IIS 7.5 - 'ColdFusion' Remote Code Execution	windows/remote/19135.py
Microsoft IIS 7.5 - WebDAV Remote Code Execution	windows/remote/20760.txt

Question 4: Plaintext Mobile Data and Unsecured Communication

- Attackers who compromise a device can read plaintext credentials and personal data. Unsecured network communication can also expose sensitive information through interception or man-in-the-middle attacks.
- Risk level: HIGH — compromise can cause privacy violations, account takeover, regulatory consequences, and reputational damage.
- Assessment: Encryption is required both at rest and in transit.
- Mitigation: Use platform secure storage such as Keychain/Keystore or encrypted preferences; encrypt sensitive data at rest; enforce HTTPS/TLS with certificate validation; use secure authentication and token handling; minimize stored data; perform regular mobile security testing.

Kali Linux Output Screenshot



The screenshot shows a Kali Linux terminal window. At the top, there's a dark bar with the text "Shellcodes: No Results" and "Noelbcode\$". Below that, the prompt "veeravinod45@kali:~\$" is visible. The main terminal area shows the command "mitmproxy --mode transparent:" being executed. The output indicates that the proxy server is listening at "http://192.168.56.1:8888". It then shows an "HTTP flow captured:" with details for a GET request to "http://insecure-app.local/api/login". The response is "HTTP/1.1 200 OK" with "Content-Type: application/json" and a JSON body: {"status": "success", "token": "abcd1234", "user": "john_dee"}.

```
Shellcodes: No Results
Noelbcode$
veeravinod45@kali:~$ mitmproxy --mode transparent:
Proxy server listening at http://192.168.56.1:8888
(Press Ctrl+C to quit)

HTTP flow captured:
  GET http://insecure-app.local/api/login HTTP/1.1
  Host: insecure-app.local
  User-Agent: Mozilla/5.0 (Linux; Android 10)

Response:
  HTTP/1.1 200 OK
  Content-Type: application/json

{"status": "success", "token": "abcd1234", "user": "john_dee"}
```

Question 5: Disabled Windows Firewall

- With the firewall disabled, exposed ports and services become reachable, allowing attackers to scan the host and attempt unauthorized access or exploitation.
- Risk level: HIGH — a simple administrative oversight can create a broad exposure window for intrusion, malware, and lateral movement.
- Assessment: Automated security policies are important because they reduce reliance on administrators remembering to restore controls.
- Mitigation: Enforce firewall policies through Group Policy/endpoint management; alert when the firewall is disabled; use least privilege; require change records and automatic rollback; monitor endpoint/network activity; perform regular audits and compliance checks.

Kali Linux Output Screenshot

```
(Sensitive45@kali:~$  
veeravinod45@kali:~$ nmap -s- 192.168.56.150  
Starting Nmap 7.94 (.86000) at 2024-05-23 10:48 IST  
Nmap scan report for 192.168.56.150:  
Host is up (0.00062s latency).  
Not shown: 65528 closed tcp ports (reset)  
  
PORT      STATE SERVICE  
21/tcp    open  ftp  
23/tcp    open  telnet  
3389/tcp  open  ms-wbt-server  
445/tcp   open  microsoft-ds  
8080/tcp  open  http-proxy  
  
Nmap done: 1 IP address (1 host up) scanned in 18.37 seconds  
veeravinod45@kali:~$
```